RANDAO-manipuláció: selfish mixing és forking támadás

1 RANDAO-manipuláció: selfish mixing és forking támadás

A fent leírt LMD-GHOST fork-choice szabály nemcsak a konszenzus alapja, hanem egyúttal a támadási felület is: a javaslók kiválasztását vezérlő véletlenség-forrás, a *RANDAO* manipulálható azáltal, hogy a támadó befolyásolja, mely blokkok kerülnek a kanonikus láncba. Ez a proof-of-work selfish miningjának proof-of-stake megfelelője. Kutatócsoportunk ezzel a kérdéssel foglalkozott, és az eredményeinkből a 2025-ös ACM CCS konferencián jelent meg publikáció [**?**]; ez a szakasz annak a legfontosabb gondolatait foglalja össze.

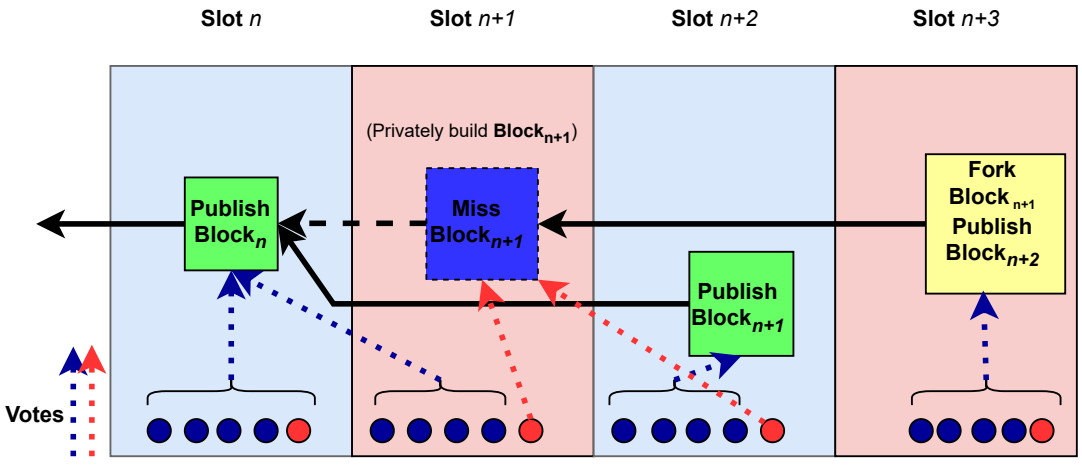
Az Ethereum proof-of-stake protokolljában a blokk-javasló validátorokat egy elosztott véletlenség-forrás (distributed randomness beacon, DRB), a RANDAO jelöli ki. Minden javasló a blokkjába tesz egy `randao_reveal` értéket, amely az epoch-szám BLS-aláírása a saját titkos kulcsával; mivel a BLS-aláírás determinisztikus, ezt az értéket a javasló nem tudja grindinggel (próbálgatással) manipulálni. A beacon kimenete az összes eddigi hozzájárulás hash-ének bitenkénti XOR-ja, és ez a kimenet határozza meg a két epochhal későbbi javaslói listát. A legfontosabb sebezhetőség abból fakad, hogy a *kihagyott* (missed) blokkok hozzájárulása nullának számít, így aki kihagy egy blokkot, az megváltoztatja a RANDAO kimenetét. Ezt kihasználva egy nagy stake-kel rendelkező validátor (pl. egy staking pool) szándékosan kihagyhat blokkokat, ha a módosult RANDAO-kimenet a jövőben több slotot oszt neki – ezt nevezzük *selfish mixingnek*. A korábbi szakirodalom (Wahrstätter, illetve Alpturer–Weinberg) megmutatta, hogy egy 20% stake-kel rendelkező szereplő selfish mixinggel kb. 0,7% extra slotot szerezhet.

Mi egy ennél jóval erősebb új stratégiát vezettünk be, a *forking támadást*, ahol a támadó nem csak a saját blokkját hagyja ki, hanem egy becsületes javasló már közzétett blokkját *forkolja ki* a kanonikus láncból. A támadás akkor lehetséges, ha a támadó az epoch-határ körül megfelelő slot-sorrenddel rendelkezik (jelölésünkben **A**$\,$**H**$\cdot$**A**), és a stake-aránya legalább 20%. Az **??**. ábra egy ilyen támadást illusztrál: a támadó titokban épít egy privát ágat, hagyja, hogy a becsületes javasló a 31. slotban publikáljon, majd a következő epoch első slotjában felfedi a hosszabb privát ágát. Ez azért működik, mert az LMD-GHOST fork-choice szabály szerint a támadó ága $2\alpha + p_{\mathsf{boost}}$ súlyt kap (ahol $p_{\mathsf{boost}} = 0{,}4$ a proposer boost), míg a becsületes ág csak $1 - \alpha$-t, így $\alpha \geq 0{,}2$ esetén a támadó ága nyer. A forking így kettős kárt okoz: egyrészt tovább torzítja a RANDAO-t

(akár megduplázva a selfish mixinggel elérhető nyereséget), másrészt közvetlenül aláássa a láncba vetett bizalmat, mert már publikált, a felhasználók által véglegesnek hitt blokkok esnek ki. Ráadásul a támadó a kiforkolt blokk MEV-jét (maximal extractable value) is megszerezheti, és a kiesett slotjait a protokoll később teljesen kompenzálja, így a támadás szinte veszteségmentes.

A támadó optimális stratégiájának kiszámításához – a selfish mixing korábbi modelljét kiterjesztve – egy Markov-döntési folyamatot (MDP) építettünk, amely a kétepochnyi időre kiterjedő állapottér miatt rendkívül nagy irányított gráfot ad. Az MDP célfüggvénye a Γ_π hosszú távú várható nettó blokknyereség (a megszerzett blokkok mínusz a feláldozott blokkok), amelyet a támadó a π politikájával maximalizál, és minden döntési állapotban a legnagyobb várható hasznú cselekvést választja: vagy nem forkol, vagy valamelyik forking-cselekvést indítja. A **??**. ábra a fő eredményünk: a forkolást és selfish mixinget együtt alkalmazó támadó szigorúan többet szerez, mint a csak selfish mixinget használó korábbi munka (AW24), és közben nő a kiforkolt becsületes blokkok száma (romló láncminőség). A **??**. ábra a stacionárius eloszlásban mutatja, milyen gyakran választ egy racionális szereplő forkolást, megbánást (regret), selfish mixinget vagy becsületes viselkedést a stake-arány függvényében; jól látszik, hogy a nagy szereplők gyakran manipulálnak: egy $\alpha = 0{,}3$ stake-ű, gazdaságilag racionális validátor az epochok 38,24%-ában manipulálja a RANDAO-t.

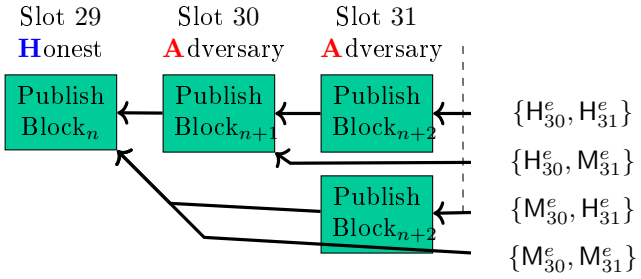
Az Ethereum mainnet valós adatain is kerestük e támadások nyomait: egyértelmű, statisztikailag szignifikáns többepochos manipulációt egyelőre nem találtunk, de mivel a protokoll kriptográfiailag nem véd ellene, racionális szereplők mellett a jövőben várható a megjelenésük. Lehetséges ellenintézkedések a hosszabb epochok, illetve a RANDAO lecserélése egy nem-torzítható DRB-re (pl. VDF-alapú vagy súlyozott threshold VRF konstrukcióra).



1. ábra: A **AH·A** forking támadás. A támadó ($\mathcal{A}$) a 30. slotban titokban épít és privát ágán szavaz, hagyja a becsületes 31. slotot publikálni, majd a következő epoch 0. slotjában felfedi a kétblokkos privát ágát, kiforkolva a becsületes blokkot. A piros/kék pontok a támadó, illetve becsületes szavazatokat jelölik.

A legegyszerűbb eset azt mutatja, hogyan dönt a támadó, ha az epoch két utolsó (tail) slotja az övé (a $\mathbf{A}^2\cdot$ sorrend). Ekkor a két blokk közzétételéről vagy kihagyásáról

négyféleképpen határozhat, mind a négy döntés más RANDAO-kimenetet (R^e) ad, és a támadó azt választja, amelyik hosszú távon a legtöbb blokkot hozza neki – ezt a döntési fát szemlélteti a ??. ábra.



2. ábra: A selfish mixing döntési fája a $\mathbf{A}^2$· támadási sorozatra. A támadó mind a négy esetre kiszámítja az R^e RANDAO-kimenetet, és a legkedvezőbbet (a legtöbb jövőbeli blokkot adót) választja. (H^e_i: az i. slot blokkját publikálja, M^e_i: kihagyja.)

A RANDAO beacon kimenetét az e epochban formálisan a következő rekurzió adja:

$$R^e := R^{e-1} \oplus \left(\bigoplus_{i=0}^{31} h(r_i^e) \right), \qquad R^0 := 0^{256}, \tag{1}$$

ahol $h(r_i^e)$ az i. slot `randao_reveal` értékének hash-e, és egy kihagyott blokk hozzájárulása $h(r_i^e) := 0^{256}$ – épp ez teszi a kimenetet a kihagyásokkal befolyásolhatóvá.

A forking támadás működésének kulcsa az LMD-GHOST súlyozás. A támadó privát ága és a becsületes ág súlya:

$$w_{\mathcal{A}} = 2\alpha + p_{\mathsf{boost}}, \qquad w_{\mathcal{H}} = 1 - \alpha, \tag{2}$$

és a támadó ága akkor nyer (azaz a becsületes blokk kiforkolható), ha $w_{\mathcal{A}} > w_{\mathcal{H}}$, ami $p_{\mathsf{boost}} = 0{,}4$ mellett épp az $\alpha \geq 0{,}2$ feltételt adja.

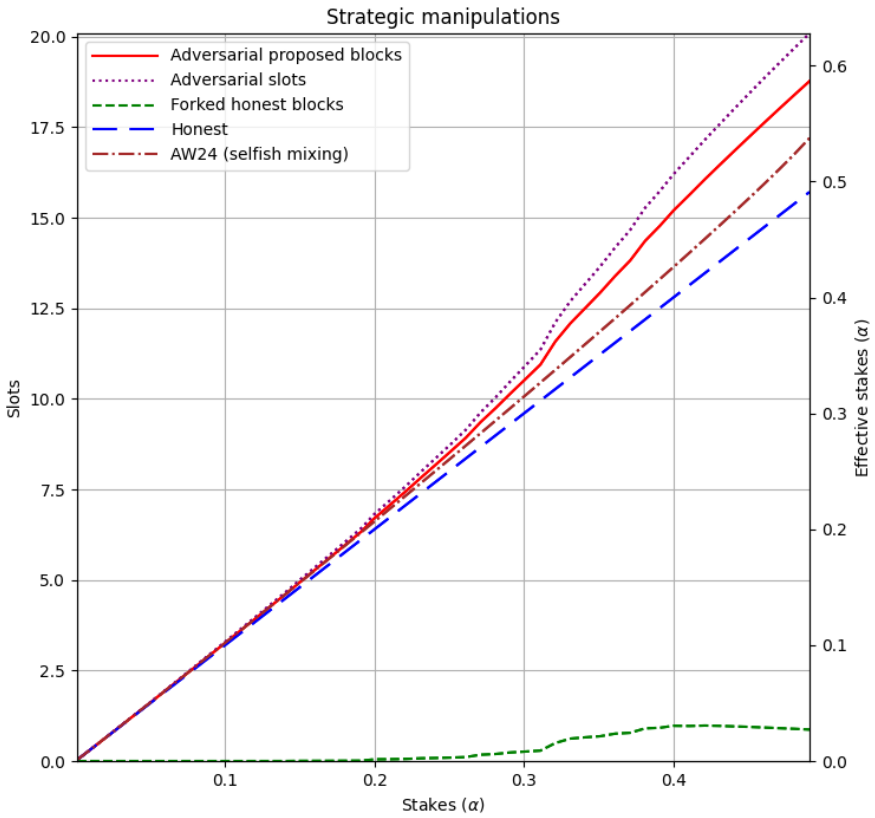
A támadó a következő hosszú távú várható nettó blokknyereséget maximalizálja a π politikájával:

$$\Gamma_\pi := \lim_{N\to\infty} \mathbb{E}\left[\frac{1}{N} \sum_{e=1}^{N} \Big(\mathscr{P}(e+2, R^e, \mathcal{A}) - \mathscr{S}(e, R^e, \mathcal{A}) \Big) \right], \tag{3}$$

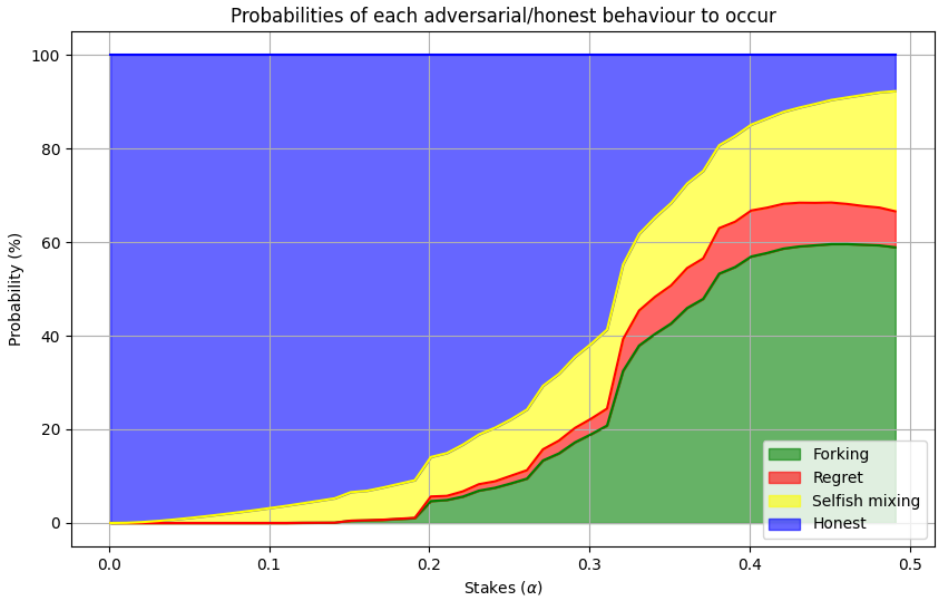
ahol $\mathscr{P}(e+2, R^e, \mathcal{A})$ a támadónak az $e+2$ epochban jutó blokkok száma a R^e kimenet mellett, $\mathscr{S}(e, R^e, \mathcal{A})$ pedig az e epochban feláldozott (kihagyott) blokkok száma.

Hivatkozások

[1] Á. Nagy, J. Tapolcai, I. A. Seres, B. Ladóczki, *Forking the RANDAO: Manipulating Ethereum's Distributed Randomness Beacon*, Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security (CCS '25), Taipei, Taiwan, 2025. DOI: 10.1145/3719027.3744852.



3. ábra: Különböző RANDAO-manipulációs stratégiák hatékonysága a stake-arány (α) függvényében. A forkolást és selfish mixinget együtt alkalmazó támadó (piros) több blokkot szerez, mint a csak selfish mixinget használó korábbi munka (AW24, barna). A zöld görbe a kiforkolt becsületes blokkok számát mutatja – ez a romló láncminőség ára.



4. ábra: Az egyes stratégiai viselkedések valószínűsége a stacionárius eloszlásban, a stake-arány függvényében. Nagy stake mellett a racionális szereplő egyre gyakrabban forkol, illetve selfish mixinget alkalmaz; $\alpha = 0{,}3$-nál az epochok 38,24%-ában manipulál.